

Security+ 3.2 · Secure Infrastructures

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 3.2 — Secure Infrastructures (5:54)

· [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Security zones (DMZ pra público, interno atrás); attack surface (menor possível); conectividade nova = risco novo. Onde colocas cada serviço DETERMINA o quanto ele é atacado.

Highlights que a prova cobra

- Zonas: DMZ separa público do interno
- Attack surface: minimiza tudo o que é acessível
- Cada nova conexão = porta nova pro atacante

Dicas de prova & Cenários Típicos

- 'place public services between internet and internal network' = DMZ

Cenário clássico de exame: 'coloca o web service numa zona que pode falar com internet mas NÃO com o interno' = DMZ/screened subnet.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 3.2 — Secure Infrastructures)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **SAAS:** Software as a Service: Modelo de nuvem onde o provedor gerencia toda a infraestrutura e aplicação (ex: Salesforce, Microsoft 365, Google Workspace).
- **PAAS:** Platform as a Service: Modelo de nuvem onde o provedor fornece o ambiente de execução e banco de dados, cabendo ao cliente desenvolver e manter a aplicação.
- **IAAS:** Infrastructure as a Service: Modelo de nuvem onde o provedor fornece poder computacional básico (VMs, rede, storage) e o cliente administra o SO e softwares.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim.
Tente responder antes de olhar.

1. Sub-rede isolada que expõe servidores públicos (web/email) protegendo a rede interna é a:

- A)** VLAN de voz
- B)** DMZ (screened subnet)
- C)** VPN
- D)** Intranet

2. Você aluga só a máquina virtual e gerencia o SO e tudo acima. Que modelo é?

- A) SaaS**
- B) PaaS**
- C) IaaS**
- D) On-premises**

3. Qual modelo de serviço de nuvem oferece maior controle sobre a infraestrutura, incluindo sistema operacional e middleware?

- A) SaaS**
- B) PaaS**
- C) IaaS**
- D) FaaS**

4. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Zonas: DMZ separa público do interno'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Permitir acesso compartilhado entre administradores com credenciais genéricas**
- D) Implementar a solução correspondente: Zonas: DMZ separa público do interno...**

5. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Attack surface: minimiza tudo o que é acessível'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível...**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

6. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Cada nova conexão = porta nova pro atacante'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Cada nova conexão = porta nova pro atacante...

7. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'place public services between internet and internal network' = DMZ'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'place public services between internet and internal network' = DMZ...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'coloca o web service numa zona que pode falar com internet mas NÃO com o interno' = DMZ/screened subnet.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'coloca o web service numa zona que pode falar com internet mas NÃO com o i...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Zonas: DMZ separa público do interno'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Zonas: DMZ separa público do interno...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Secure Infrastructures): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 3.2), um analista avalia o seguinte requisito técnico: 'Attack surface: minimiza tudo o que é acessível'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — DMZ (screened subnet).

✓ **Por que está certa:** A alternativa correta é 'DMZ (screened subnet)'. Uma DMZ (Zona Desmilitarizada), também chamada de sub-rede filtrada (screened subnet), é um segmento de rede isolado que fica entre a rede interna confiável e a rede externa não confiável (como a Internet). Ela hospeda servidores públicos, como web, e-mail, DNS e FTP, que precisam ser acessíveis externamente. O objetivo é que, se um desses servidores for comprometido, o atacante não tenha acesso direto à rede interna, pois há firewalls controlando o tráfego entre a DMZ e a rede interna. O CompTIA Security+ SY0-701, no domínio de Arquitetura e Design (2.2), descreve a DMZ como uma zona de segurança para expor serviços públicos de forma controlada. A questão descreve exatamente essa função: sub-rede isolada que expõe servidores públicos protegendo a rede interna.

✗ **Por que as outras estão erradas:**

- **VLAN de voz:** VLAN de voz é uma rede local virtual dedicada a tráfego de VoIP (voz sobre IP), separando-o dos dados para garantir qualidade de serviço (QoS) e segurança. Ela não é projetada para expor servidores públicos à Internet; pelo contrário, isola o tráfego de voz. Não oferece o isolamento entre rede interna e externa que uma DMZ proporciona. Portanto, não atende ao requisito de proteger a rede interna enquanto expõe serviços públicos.
- **VPN:** VPN (Virtual Private Network) é uma tecnologia que cria um túnel criptografado para transmitir dados de forma segura através de redes não confiáveis, permitindo acesso remoto ou interconexão de filiais. Embora melhore a segurança da comunicação, não é uma sub-rede isolada para hospedar servidores públicos. Uma VPN pode ser usada para acessar a DMZ, mas não substitui a DMZ. A questão pede uma zona de rede que exponha servidores públicos, o que não é a função primária de uma VPN.
- **Intranet:** Intranet é uma rede privada interna que utiliza tecnologias da Internet (como HTTP, FTP) para compartilhar informações dentro de uma organização. Ela é acessível apenas por usuários autorizados e não é exposta ao público externo. Portanto, não serve para hospedar servidores públicos que precisam ser acessados pela Internet. A intranet é o oposto de uma DMZ nesse aspecto: é interna e restrita, não uma zona de exposição controlada.

2) C — IaaS.

✓ **Por que está certa:** IaaS (Infrastructure as a Service) é o modelo de computação em nuvem em que o provedor oferece recursos de infraestrutura virtualizados, como máquinas virtuais, armazenamento, redes e firewalls, enquanto o cliente gerencia o sistema operacional, middleware, runtime, aplicações e dados. No enunciado, o cliente aluga apenas a máquina virtual e gerencia o SO e tudo acima, o que corresponde exatamente à divisão de responsabilidades do IaaS conforme definido pelo NIST SP 800-145 e pelo syllabus da CompTIA Security+ (domínio 3.1 – Arquitetura e Design de Segurança).

✗ **Por que as outras estão erradas:**

- **SaaS:** SaaS (Software as a Service) é o modelo em que o provedor entrega aplicações completas prontas para uso, gerenciando toda a pilha de infraestrutura, sistema operacional, middleware e a própria aplicação. O cliente apenas acessa o software via interface web ou API, sem gerenciar SO ou qualquer camada inferior. No cenário descrito, o cliente gerencia o SO e tudo acima, o que é incompatível com SaaS, onde essa responsabilidade é do provedor.
- **PaaS:** PaaS (Platform as a Service) oferece um ambiente de desenvolvimento e execução gerenciado, incluindo sistema operacional, runtime, middleware e serviços de banco de dados. O cliente gerencia apenas as aplicações e os dados, não o SO. No enunciado, o cliente gerencia o SO

e tudo acima, o que excede o escopo de responsabilidade do cliente em PaaS. Portanto, não é o modelo correto.

- *On-premises*: On-premises (ou on-prem) refere-se à infraestrutura de TI instalada e mantida fisicamente nas dependências da própria organização, sem envolvimento de nuvem. O cliente gerencia tudo, desde o hardware até as aplicações, e não há aluguel de máquina virtual de um provedor externo. O enunciado descreve explicitamente o aluguel de uma máquina virtual, o que caracteriza um modelo de nuvem, não on-premises.

3) C — IaaS.

✓ **Por que está certa:** A alternativa correta é IaaS (Infrastructure as a Service). No modelo IaaS, o provedor de nuvem entrega recursos fundamentais de computação — máquinas virtuais, armazenamento em bloco, redes virtuais e firewalls —, mas o cliente mantém o controle sobre a pilha que vai do sistema operacional convidado para cima. Isso significa que o cliente é responsável por instalar e aplicar patches no SO, configurar middleware (servidores de aplicação, bancos de dados, runtimes), gerenciar identidades e políticas de acesso, além de proteger os dados. Esse é o modelo que oferece o maior grau de controle sobre a infraestrutura entre as opções apresentadas, pois o cliente pode escolher a distribuição Linux, a versão do kernel, o servidor web, a JVM, etc. A CompTIA classifica IaaS como o modelo de serviço em nuvem que fornece controle sobre a infraestrutura subjacente, incluindo SO e middleware, enquanto o provedor gerencia a virtualização, os servidores físicos, o armazenamento e a rede física.

✗ **Por que as outras estão erradas:**

- *SaaS*: SaaS (Software as a Service) é o modelo em que o provedor entrega uma aplicação completa e pronta para uso, como Microsoft 365, Salesforce ou Google Workspace. O cliente não gerencia absolutamente nada da pilha: não tem acesso ao sistema operacional, ao middleware, ao runtime, ao banco de dados nem à infraestrutura. Toda a responsabilidade operacional e de segurança da aplicação até a camada física é do provedor. Portanto, SaaS oferece o menor controle sobre a infraestrutura, e não o maior. É o oposto do que o enunciado pede.
- *PaaS*: PaaS (Platform as a Service) fornece um ambiente gerenciado para desenvolvimento e execução de aplicações, incluindo sistema operacional, runtime, middleware e serviços de banco de dados já configurados e mantidos pelo provedor. O cliente controla apenas a aplicação e, em alguns casos, configurações limitadas do ambiente. Embora ofereça mais controle que SaaS, o cliente não gerencia o sistema operacional nem o middleware — exatamente os elementos citados no enunciado. Logo, PaaS não atende ao requisito de maior controle sobre SO e middleware.
- *FaaS*: FaaS (Function as a Service) é um modelo de computação serverless em que o cliente escreve funções individuais e o provedor gerencia totalmente a infraestrutura, o sistema operacional, o runtime e o escalonamento. O controle do cliente se limita ao código da função e a algumas configurações de gatilho e memória. Não há acesso ao sistema operacional nem ao middleware, o que torna FaaS o modelo com o menor nível de controle sobre a infraestrutura, e não o maior.

4) D — Implementar a solução correspondente: Zonas: DMZ separa público do interno....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Zonas: DMZ separa público do interno.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam

ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) C — Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Attack surface: minimiza tudo o que é acessível.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) D — Implementar a solução correspondente: Cada nova conexão = porta nova pro atacante....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Cada nova conexão = porta nova pro atacante.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: 'place public services between internet and internal network' = DMZ....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): 'place public services between internet and internal network' = DMZ.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: 'coloca o web service numa zona que pode falar com internet mas NÃO com o i....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): 'coloca o web service numa zona que pode falar com internet mas NÃO com o interno'=DMZ/screened subnet..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: Zonas: DMZ separa público do interno....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Zonas: DMZ separa público do interno.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Attack surface: minimiza tudo o que é acessível....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 3.2 (Secure Infrastructures): Attack surface: minimiza tudo o que é acessível.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

